JÖNKÖPING UNIVERSITY
School of Engineering

Privacy and ethics

Lecture 1, Information Security, 7,5 ECTS

Björn Praestegaard Larsen
bjorn.larsen@ju.se

Objective

- Know general privacy issues
- Understand what GDPR 2016/679 is
- Reflect on ethics and moral
- Differentiate between laws and ethics
- Ethical principles

Introduction to privacy

- Privacy is hard to define
- *"The right to be let alone."* (Warren & Brandeis, 1890)
- Privacy is the right to control who knows certain aspects about you, your communications, and your activities
- Many types of data are considered private

Introduction to privacy

- Privacy can be seen as a concept:
  - What is it
  - How and why it is valued
- Privacy can also be seen as a right:
  - How it is or how it should be protected by law, policies, and technology
- Depends on context
- (Data) subject: person or entity being described by the data
- Data controller/owner: person or entity that holds the data

Computer-related privacy issues

- Data collection
- Notice and consent
- Control and ownership of data

Privacy laws - GDPR

- The General Data Protection Regulation (GDPR 2016/679) was activated as a cross European law on the 25th of May 2018.
- It holds 177 guidelines and 99 articles (paragraphs).
- Governs the type of notice that must be provided to people regarding how their identifiable data is used
- Governs how companies are allowed to use and process an individuals identifiable data

Its purpose is to secure the protection of physical individual's personal data.

GDPR - fundamental principles

- The Swedish Data Protection Authority (Integritetsskyddsmyndigheten) has summarized the fundamental GDPR principles:

- Lawfulness, fairness and transparency

- Purpose limitation

- Data minimization…

What is GDPR

- The General Data Protection Regulation (GDPR 2016/679) was activated as a cross European law on the 25th of May 2018.
- It holds 177 guidelines and 99 articles (paragraphs).
- Governs the type of notice that must be provided to people regarding how their identifiable data is used
- Governs how companies are allowed to use and process identifiable data

Its purpose is to secure the protection of physical individual's personal data.

What is personal data?

- Any information which can be directly or indirectly connected to a physical individual which is alive is considered by GDPR to be personal data.
- Images, videos and recordings of individuals is to be considered personal data even if names of these individuals are missing.
- The information does not necessarily need to be administrated within a computer, it can exist in paper format, same rules still apply.

Individuals rights are increased with GDPR

- Right to information
- Right of access to information
- Right to rectification of information
- Right to erasure (right to be forgotten)
- Right to restriction of processing
- Right to notification of correction or deletion
- Right to data transfer
- Right to object against usage
- Right to object to automated decision-making

GDPR - fundamental principles

…

- Accuracy
- Storage limitation
- Integrity and confidentiality
- Accountability

What is Data Processing?

Processing of data involves any and all of the following:

- Adapting
- Altering
- Collecting
- Combining
- Consulting
- Destroying
- Disclosing
- Erasing
- Organising
- Recording
- Retrieving
- Storing
- Structuring
- Using

What is Needed to Process Data?

- A “lawful basis” for doing so
- A “lawful basis” can be:
  - When required for a contract
  - When required for public interest
  - When required to comply with a law
  - When required to protect an individual’s life
  - When required for the legitimate interests of a third party (no sensitive data)
  - When freely given consent for a specific purpose has been provided
- If sensitive data is being processed, explicit consent for those data elements is required.

Is GDPR the only law?

Some laws and regulations affecting us (Sweden)

In Sweden there are many laws that govern personal data. These laws are primarily complementing GDPR.

- New Data Protection Act (SE) 2018:218
- New crime data act (SE) 2018:1699
- The Protective Security Act (SE) 2018:585
- The Patient Data Act (SE) 2008:355 (ändrad 2018)
- Camera Surveillance law (SE) 2018:1200
- Swedish Covert Surveillance of Data Act (2020:62)

To whom does GDPR apply?

Those who offer goods or services to persons in the EU/EEA

- European Economic Area (EEA) = European Union (EU) + Iceland, Liechtenstein, Norway, & UK

Those who control and process data about persons in the EU/EEA

- Personal Data = any information that can identify a person
- Sensitive Data = race/ethnicity, political opinions, religious/philosophical beliefs, union membership, genetic data, biometric data, health data, data concerning a person's sex life or sexual orientation.

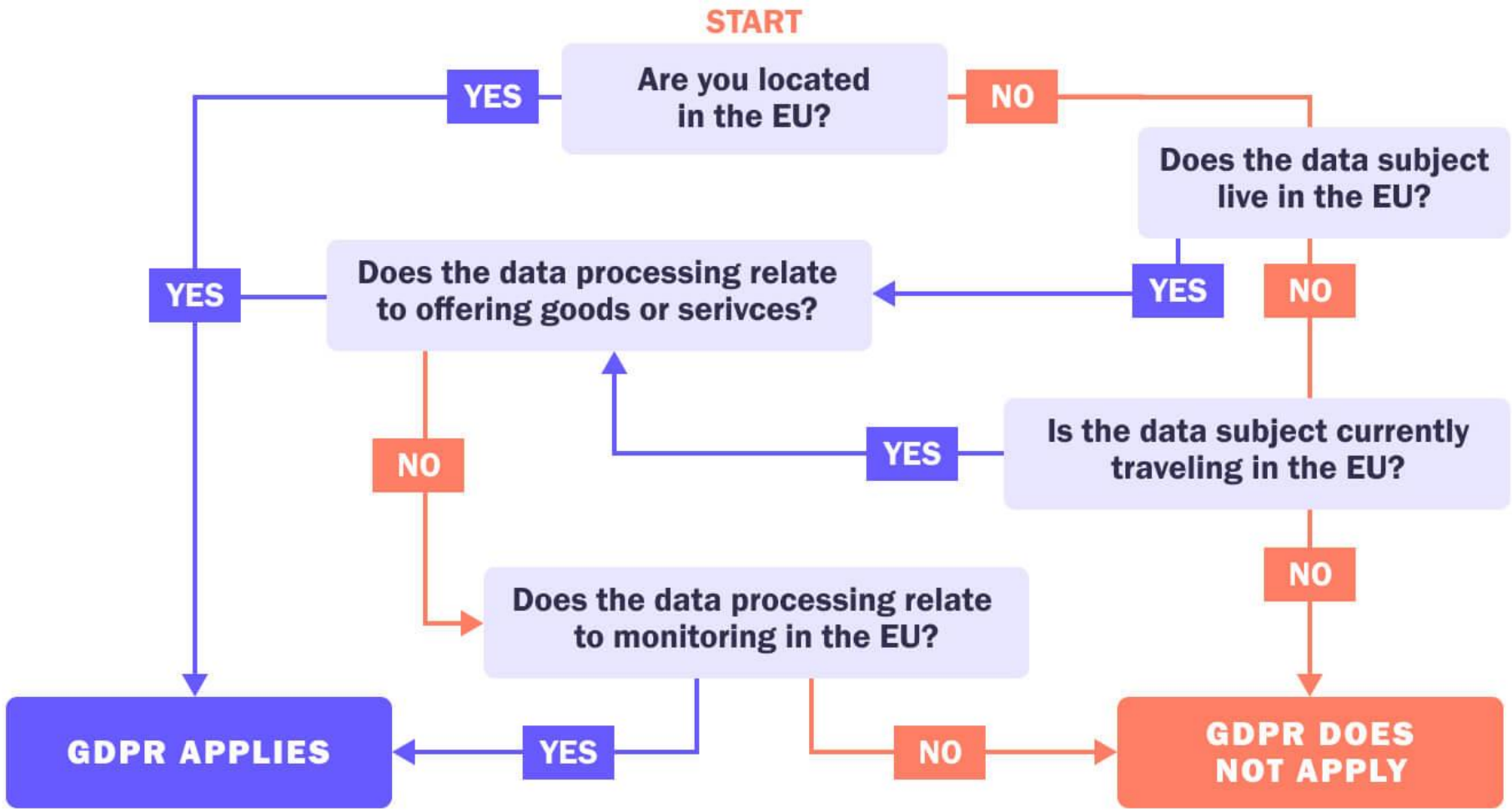
Is GDPR only applicable for companies?

In general GDPR is applicable for all kinds of activities no matter who is managing the personal data, this includes, but is not limited to.

- Companies
- Associations
- Organisations
- Authorities
- Private individuals

There are exceptions, especially when it comes to regulating private individuals administration of personal data.

DOES GDPR APPLY TO ME?



The Swedish Data Protection Authority carries out checks

- If they received a complaint
  - Person who is registered with you
  - Former employee
  - Competitor
- If they drew attention to an industry
  - Reported misconduct
  - New industries
  - Industries where the risk of abuse is high
- Unannounced inspections may occur

If you do not comply with GDPR

Administrative penalty fees

- The fee can be a maximum of 20 million euros or four percent of the company's global annual turnover
- How high the penalty fee will depend partly on which provision the violation applies to, and partly on the circumstances of the case.
- In Sweden, authorities can also be imposed penalty fees.
- The Swedish Data Protection Authority can also issue warnings if a planned processing of personal data is likely to violate the provisions of the regulation.

Privacy laws - GDPR

- GDPR Enforcement Tracker
  - Overview of fines and penalties which data protection authorities within the EU have imposed.
  - https://www.enforcementtracker.com/
    - E.g., British Airways 200MEUR, Marriott 110MEUR, Google 50MEUR…

Ways of tracking - Cookies and web bugs

- Cookies
  - Cookies are a way for websites to store data locally on a user's machine
  - They may contain sensitive personal information, such as credit card numbers
  - Third-party tracking cookies

- Web bugs/web beacon/tracking bug/…
  - A Web bug is used on a web page or in an email to confirm and invisibly allow for checking that a user has accessed some content
  - It can be more active than a cookie and can immediately trigger information about user behavior to advertising services

Ways of tracking - Spyware

- Spyware is code designed to spy on a user by collecting data
- General spyware
  - Advertising applications, identity theft
- Hijackers
  - Hijack existing programs and use them for different purposes, such as reconfiguring file-sharing software to share sensitive information
- Adware
  - Displays selected advertisements in pop-up windows or the main browser window
  - Often installed in a misleading way as part of other software packages

Information security and the law

- Internet is special
  - Where? What laws? Jurisdiction?

- Information is special:
  - Like material goods, information is valuable
  - Unlike material goods, information:
    - Is not depletable
    - Can be replicated
    - Has a minimal marginal cost
    - Often has a time-dependent value
    - Often transferred intangibly
  - All these factors impact how information is treated under the law
    - E.g., in the context of information, what is “theft”?

How do we protect?

- Copyrights
- Patents
- Trade secrets

Ethics

- Ethics and/or moral philosophy: part of philosophy field
- There are ethical differences across cultures
- Ethics can change over time
- We make ethical judgements daily
- Your ethics/morals can be contextual and change:
  - I never lie…. except when…
  - I know that downloading the Hollywood blockbuster movie is illegal, but they have already earned more than enough… at least I paid for the… (self-regulation)
- What is/isn't ethics?

Why is ethics important?

- “If you are very strong, you must also be very kind.” Pippi Longstocking (Astrid Lindgren)
- Ethics is critical in engineering and science (tech)!
- Ethics is an open-ended, complex challenge that is continuously evolving.

Law vs. ethics

Law	Ethics
Described by formal, written documents	Described by unwritten principles
Interpreted by courts	Interpreted by each individual
Established by legislatures representing all people	Presented by philosophers, religions, professional groups
Applied to everyone	Chosen personally
Priority determined by courts if two laws conflict	Priority determined by an individual if two principles conflict
”Right” arbitrated finally by court	Not arbitrated externally
Enforced by police and courts	Enforced by intangibles such as principles and beliefs

Our field is full of examples

- Vulnerability disclosure
- Use of hacking tools
- Privacy
- Monitoring
- Surveillance
- …

Examining a situation for ethical issues

- How can we approach issues of ethical choice in security?
  - Understand the situation
  - Know several theories of ethical reasoning
  - List the ethical principles involved
  - Determine which principles outweigh others
  - Make and defend an ethical choice

Ethical principles

- Ethics is a big field, this is one perspective!
- View issues from different perspectives → Different lenses

	Consequence-Based	**Rule-Based**
Individual	based on consequences to individual	based on rules acquired by the individual—from religion, experience, analysis
Universal	based on consequences to all of society	based on universal rules, evident to everyone

Consequence-based principles (teleological)

- Focuses on the consequences of an action.
- If we sum up all good and bad things from all stakeholders, how can we maximize long-term well-being and happiness?
  - Quantitative approach (utilitarianism)
  - What actions can we take?
  - What rules would lead to it?
- How can we create common good? Make society flourish?
- The ends justify the means!

Rule-based principles (deontolological)

- There are certain universal, self-evident, natural rules that specify our proper conduct.
- We have responsibilities to one another:
  - the right to know, the right to privacy, the right to fair compensation for work…
- Based on the belief that human beings have a set of duties built-in
  - What rules (or duties at work) must we always follow, whatever the consequences?
    - Are there any such rules or duties?
- What is the right behavior?
- Do we have a moral obligation to…?

Everyone have their own standards which they follow.

Do not expect these to match yours.

JÖNKÖPING UNIVERSITY

School of Engineering